Processor agreement (Article 28 GDPR)

A model agreement between a controller and a processor under Article 28 GDPR, with four annexes to fill in and a line-by-line check for an agreement already signed. For data protection officers, lawyers and small-company owners; Italy and Germany in depth.

FOR

Controllers and processors in the EU, public or private, that need the written agreement required by Article 28 GDPR. The model follows EU law; the points that differ in Italy and Germany are in their own sections.

NOT COVERED

Joint controllers (Article 26 GDPR) and independent controllers, who need a different document. The transfer tools themselves (standard clauses for transfers, transfer assessments). Processing for law enforcement under Directive (EU) 2016/680 (in Germany, Part 3 of the Federal Data Protection Act (BDSG), section 62) and processing by EU institutions under Regulation (EU) 2018/1725. Commercial terms such as price, liability caps and insurance, which are left as fill-in fields. Not confirmed, so left out: guidance from Italy's data protection authority (the Garante) written specifically on processors beyond the three Garante pages listed in the sources (none was found in the saved library).

LAW AS OF

GDPR (Regulation (EU) 2016/679) as in force 7 Nov 2026; Commission Implementing Decision (EU) 2021/915 of 4 June 2021; Guidelines 07/2020 of the European Data Protection Board (EDPB), version 2.1 (20 Sep 2022); EDPB Opinion 22/2024 (7 Oct 2024); Joint Opinion 1/2021 of the EDPB and the European Data Protection Supervisor (EDPS) (14 Jan 2021); EDPB register of Article 28(8) clauses, read 7 Nov 2026; Italian Personal Data Protection Code (Codice privacy) art. 2-quaterdecies, as on Normattiva (updated to the act published on 19 Feb 2026), read 8 Nov 2026; section 203 of the German Criminal Code (StGB), gesetze-im-internet.de, read 7 Nov 2026; Federal Commissioner for Data Protection and Freedom of Information (BfDI) Mustervereinbarung zur Auftragsverarbeitung, version 2.1; conference of German data protection authorities (DSK) Kurzpapier Nr. 13 (as of 17 Dec 2018, listed by the DSK as under revision); web pages of Italy's data protection authority (Garante) read 7 Nov 2026; section 43e of the Federal Lawyers' Act (BRAO), gesetze-im-internet.de, read 8 Nov 2026.

VERSION

1.1, 8 November 2026

Check before you use it

Is the other party a processor? Article 28 applies only where a separate organisation processes personal data on the controller's behalf (Article 4(8)). **Two routes.** The parties may sign their own contract or other legal act (Article 28(3)), as in this model, or use standard contractual clauses adopted by the Commission (Article 28(7): Implementing Decision (EU) 2021/915) or by a supervisory authority (Article 28(8)). Either way the agreement is in writing, which includes electronic form (Article 28(9)). **Mistakes found in fined cases:** no agreement at all, a sub-processor used without authorisation, a processor acting on its own initiative, a controller that did not check its processors (cases in the Italy and Germany sections). **Not for** joint controllers (Article 26) or two independent controllers.

Before using the model

Who is a processor

A processor is a *"natural or legal person, public authority, agency or other body which processes personal data on behalf of the controller"* (Article 4(8) GDPR). The controller is the one that decides the purposes and means of the processing (Article 4(7)). The European Data Protection Board (EDPB), the body of EU regulators: *"Two basic conditions for qualifying as processor exist"*: the processor is a separate entity from the controller, and it processes the data on the controller's behalf (EDPB Guidelines 07/2020, p. 3).

The label in the contract does not decide the role. Where an agreement does not match who really controls the processing, the EDPB says it *"may be set aside"* (Guidelines 07/2020, footnote 42). A provider that uses the data for its own purposes is a controller: in the EDPB's example, a travel agency and the airlines and hotels it sends bookings to are each controllers, with no processor between them (para. 92).

Two routes: an own contract or standard clauses

Article 28(3) requires *"a contract or other legal act under Union or Member State law, that is binding on the processor with regard to the controller"* (Article 28 GDPR). The parties may write their own, or base it *"in whole or in part"* on standard contractual clauses (Article 28(6)). The EDPB says there is *"no obligation"* to use standard clauses, and that they are not *"necessarily preferred"* over an individual contract (Guidelines 07/2020, para. 106).

The Commission's clauses. The clauses in the annex to Decision (EU) 2021/915 *"fulfil the requirements"* of Article 28(3) and (4) (Article 1 of the Decision). They are used unchanged: the parties *"undertake not to modify the Clauses, except for adding information to the Annexes or updating information in them"* (Clause 2(a)). They may sit inside a wider contract, with added clauses that do not contradict them (Clause 2(b)). They *"do not by themselves ensure compliance with obligations related to international transfers in accordance with Chapter V"* GDPR (Clause 1(f)): transfers to third countries need their own tool.

Clauses of a supervisory authority. The EDPB register of Article 28(8) clauses lists three sets: Denmark (10 December 2019), Lithuania and Slovenia (both 13 April 2023). It lists none from an Italian or German authority (EDPB register, read 7 November 2026).

This model is not the Commission's clauses. It is an individual contract under Article 28(3), in Fino's own wording. It follows the order of Article 28(3) and the structure of the official models listed in the sources, not their text. Parties who want to rely on the Commission's clauses use the official text unchanged.

Specific, not a copy of the law

The EDPB says the agreement *"should not merely restate the provisions of the GDPR"*; it should say how each requirement will be met (Guidelines 07/2020, para. 112). That is why this model puts the detail in four annexes. A contract signed before the GDPR applied and never brought into line with it infringes Article 28(3), says the EDPB (para. 103).

The model agreement

Fill in every field. Where the model offers options, keep one and delete the rest. Each italic line explains the clause above it in plain words; delete these lines before signing.

1. Parties and scope

1.1 This processing agreement is made between `NAME, ADDRESS AND REGISTRATION NUMBER OF THE CONTROLLER` (the controller) and `NAME, ADDRESS AND REGISTRATION NUMBER OF THE PROCESSOR` (the processor). It governs the processing of personal data that the processor carries out on behalf of the controller under `TITLE AND DATE OF THE MAIN SERVICE CONTRACT` (the Main Contract).

Art. 28(3) GDPR

Names the two parties and ties this agreement to the service contract it belongs to.

1.2 Terms defined in the GDPR, such as personal data, processing, data subject and personal data breach, have the meaning given to them in Article 4 GDPR.

Art. 4 GDPR

The legal terms mean what the GDPR says they mean. Data subject: the person the data is about. Supervisory authority: the national data protection regulator.

1.3 If this agreement conflicts with the Main Contract or any other agreement between the parties on the protection of personal data, this agreement prevails. This does not apply to standard contractual clauses adopted by the Commission that the parties have signed; where they conflict with this agreement, those clauses prevail, as they themselves provide.

EDPB Guidelines 07/2020, para. 103; Decision 2021/914, Annex, Clause 5; Decision 2021/915, Annex, Clause 4

The data protection terms win over the commercial contract, but the Commission's standard clauses, if signed, win over this agreement. The EDPB recommends keeping the Article 28 terms together in one place.

2. The processing

2.1 Annex 1 describes the subject matter and duration of the processing, its nature and purpose, the types of personal data and the categories of data subjects. The processor processes the personal data only for the purposes stated in Annex 1.

Art. 28(3), first subparagraph, GDPR

Annex 1 says what is processed, about whom, how, why and for how long.

The EDPB asks for detail: the type of personal data *"should be specified in the most detailed manner as possible"*, and writing only *"personal data pursuant to Article 4(1) GDPR"* is not adequate (Guidelines 07/2020, para. 114).

3. Obligations and rights of the controller

3.1 The controller remains responsible for ensuring that the processing it entrusts to the processor complies with the GDPR. It provides the processor with the personal data described in Annex 1, gives its instructions in documented form and may verify, before and during the processing, that the processor complies with this agreement and the GDPR, including through the audits in clause 12.

Art. 28(3) and Art. 24 GDPR; EDPB Guidelines 07/2020, para. 114

Article 28(3) asks the contract to set out the controller's own duties and rights too.

4. Instructions

4.1 The processor processes the personal data only on documented instructions from the controller, including with regard to transfers of personal data to a third country or an international organisation, unless Union or Member State law to which the processor is subject requires it to do otherwise. In that case the processor informs the controller of that legal requirement before processing, unless that law prohibits such information on important grounds of public interest.

Art. 28(3)(a) GDPR

The processor acts only on the controller's instructions. If an EU or national law requires something else, it says so first, unless that law forbids it.

4.2 This agreement and its annexes are the controller's initial instructions. The controller may give further instructions in writing, including by email, through the persons named in Annex 4. Both parties keep every instruction together with this agreement.

Art. 28(3)(a) GDPR; EDPB Guidelines 07/2020, para. 118

Every later instruction is written down and kept, so it can be shown later.

4.3 The processor immediately informs the controller if, in its opinion, an instruction infringes the GDPR or other Union or Member State data protection provisions. The processor may suspend carrying out that instruction until the controller confirms, changes or withdraws it.

Art. 28(3), second subparagraph, GDPR; EDPB Guidelines 07/2020, para. 149

If the processor thinks an instruction is unlawful, it says so at once. The second sentence, on suspension, is optional: the EDPB gives it as an example. Delete it if the parties do not agree it.

Article 28(3) states this duty in a separate sentence: *"the processor shall immediately inform the controller if, in its opinion, an instruction infringes this Regulation or other Union or Member State data protection provisions"* (Article 28 GDPR). The GDPR does not say what happens next. The EDPB recommends agreeing it, for example suspension of the instruction, or termination if the controller insists (Guidelines 07/2020, para. 149). Clause 15.3 provides for termination.

4.4 The processor does not process the personal data for its own purposes or for the purposes of anyone else. If the processor infringes the GDPR by determining the purposes and means of processing, it is considered a controller in respect of that processing.

Art. 28(10) GDPR

A processor that starts deciding why and how the data is used becomes a controller for that use, with a controller's duties.

On the words *"unless required to do so by Union or Member State law to which the processor is subject"*, the EDPB calls them *"highly recommended but not mandatory"*. Where data is transferred outside the European Economic Area (EEA: the EU plus Iceland, Liechtenstein and Norway), it considers it unlikely that a looser phrase such as *"unless required to do so by law or binding order of a governmental body"* is enough by itself (EDPB Opinion 22/2024, executive summary).

5. Confidentiality

5.1 The processor gives access to the personal data only to those members of its staff who need it to perform the Main Contract. It ensures that every person authorised to process the personal data has committed to confidentiality or is under an appropriate statutory obligation of confidentiality. The commitment covers all the personal data processed for the controller and continues after the person's work on the data ends.

Art. 28(3)(b) GDPR; EDPB Guidelines 07/2020, paras. 123-124

Only staff who need the data see it, and each of them is bound to secrecy, by contract or by law.

5.2 The processor ensures that any person acting under its authority who has access to the personal data processes them only on instructions from the controller, unless Union or Member State law requires otherwise.

Art. 29 and Art. 32(4) GDPR

Everyone working under the processor follows the controller's instructions too.

6. Security

6.1 The processor takes all measures required under Article 32 GDPR. It implements at least the technical and organisational measures described in Annex 2, which the parties have chosen taking into account the state of the art, the costs of implementation, the nature, scope, context and purposes of the processing and the risks for the rights and freedoms of natural persons.

Art. 28(3)(c) and Art. 32(1) GDPR

The processor protects the data at the level the risk calls for. Annex 2 lists the concrete measures.

6.2 The processor reviews the measures at least REVIEW INTERVAL, FOR EXAMPLE EVERY 12 MONTHS and after any significant change to the processing. It replaces a measure only with one that gives at least the same level of security. It notifies the controller of any material change in advance and makes it only with the controller's written approval.

Art. 32(1)(d) GDPR; EDPB Guidelines 07/2020, para. 126

Measures are checked regularly and never weakened without the controller's agreement.

7. Sub-processors

Keep Option A or Option B and delete the other.

7.1 **Option A, specific authorisation.** The processor does not engage another processor (a sub-processor) without the controller's prior specific written authorisation. It sends each request at least NUMBER days before the engagement, with the information listed under Annex 3. A request not answered within that time is refused.

Art. 28(2) GDPR; EDPB Guidelines 07/2020, paras. 152-155

Each new sub-processor needs the controller's written yes. Silence means no.

7.2 **Option B, general authorisation.** The controller gives its general written authorisation for the sub-processors listed in Annex 3. The processor informs the controller in writing of any intended addition or replacement of a sub-processor at least NUMBER days in advance, with the information listed under Annex 3, so that the controller can object. If the controller objects, CONSEQUENCE OF AN OBJECTION.

Art. 28(2) GDPR; EDPB Guidelines 07/2020, paras. 156-158

The controller agrees in advance to a list. The processor announces every change, and the controller can say no. In the field, write what follows an objection, for example: the processor does not engage the sub-processor, or either party may end the affected service within a set number of days.

The duty to inform is active. The EDPB says it is *"not sufficient"* for the processor to give access to a list of sub-processors updated from time to time *"without pointing to each new sub-processor envisaged"* (Guidelines 07/2020, footnote 54). Under a general authorisation, the controller's silence within the agreed time can be read as authorisation (para. 157).

7.3 Where the processor engages a sub-processor for specific processing activities on behalf of the controller, it imposes on that sub-processor, by a contract or other legal act under Union or Member State law, the same data protection obligations as those set out in this agreement, in particular sufficient guarantees to implement appropriate technical and organisational measures. These include the right of the controller, or an auditor it mandates, to audit the sub-processor.

Art. 28(4) GDPR; EDPB Guidelines 07/2020, paras. 129 and 160

The same duties pass down the chain. The words may differ; the substance may not.

7.4 Where a sub-processor fails to fulfil its data protection obligations, the processor remains fully liable to the controller for the performance of that sub-processor's obligations.

Art. 28(4), last sentence, GDPR

The processor answers to the controller for its sub-processors.

7.5 The processor keeps Annex 3 up to date with the name, address, contact person, processing activity and location of every sub-processor, at every level of the chain. At the controller's request, it provides a copy of a sub-processor contract and any changes to it; it may black out text only as far as necessary to protect business secrets or other confidential information, including personal data.

EDPB Opinion 22/2024, executive summary; Decision 2021/915, Annex, Clause 7.7(c)

The controller always knows who handles its data, down the whole chain.

8. Requests from data subjects

8.1 Taking into account the nature of the processing, the processor assists the controller by appropriate technical and organisational measures, insofar as this is possible, in fulfilling the controller's obligation to respond to requests from data subjects exercising their rights under Chapter III GDPR. Annex 2, part B, describes these measures.

Art. 28(3)(e) GDPR

The processor helps the controller answer people who ask to see, correct, delete or move their data.

8.2 The processor forwards to the controller any request it receives from a data subject within NUMBER working days, and does not answer it unless the controller authorises it in writing.

EDPB Guidelines 07/2020, paras. 131-132

The controller decides on each request. Its legal deadlines do not pause while it waits for the processor.

9. Help with security, breaches and impact assessments

9.1 Taking into account the nature of the processing and the information available to it, the processor assists the controller in ensuring compliance with Articles 32 to 36 GDPR: security of processing, notification of personal data breaches to the supervisory authority and their communication to data subjects, data protection impact assessments and prior consultation of the supervisory authority. Annex 2, part B, describes how.

Art. 28(3)(f) GDPR

The processor helps with the controller's duties on security, breach reports, impact assessments and consulting the regulator.

10. Personal data breaches

10.1 The processor notifies the controller of any personal data breach affecting the personal data processed under this agreement, including a breach at a sub-processor, without undue delay after becoming aware of it and in any case within NUMBER hours, by CHANNEL, FOR EXAMPLE EMAIL AND PHONE to the contact point in Annex 4.

Art. 33(2) GDPR; EDPB Guidelines 07/2020, para. 136

The GDPR sets no number of hours for the processor; the EDPB says the parties may agree one. The controller itself must notify the authority without undue delay and, where feasible, not later than 72 hours after becoming aware of the breach (Article 33(1)).

The EDPB: *"it may be appropriate for the parties to include in the contract a specific timeframe (e.g. number of hours) by which the processor should notify the controller"* (Guidelines 07/2020, para. 136). The Commission's draft clauses set 48 hours; the EDPB and the European Data Protection Supervisor (EDPS) suggested leaving the time to the parties (Joint Opinion 1/2021, para. 42), and the adopted clauses say *"without undue delay"* with no number of hours (Decision 2021/915, Annex, Clause 9.2).

10.2 The notification describes, as far as possible: the nature of the breach, including the categories and approximate number of data subjects and of personal data records concerned; a contact point for more information; the likely consequences; and the measures taken or proposed to address the breach and mitigate its possible adverse effects. Information not yet available is provided in phases without undue further delay.

Art. 28(3)(f) and Art. 33(3)-(4) GDPR

The notice gives the controller what it needs for its own report to the authority.

10.3 The processor does not notify the supervisory authority or inform data subjects on the controller's behalf unless the controller instructs it in writing. If it does so on instruction, it sends the controller a copy of the notification and of the information given to data subjects.

EDPB Guidelines 07/2020, para. 136

Reporting to the authority stays the controller's legal duty, even when the processor sends the report.

11. End of the processing

11.1 After the end of the provision of services relating to the processing, the processor, at the choice of the controller, deletes or returns all the personal data to the controller, and deletes existing copies, unless Union or Member State law requires storage of the personal data. The controller's choice is: CONTROLLER'S CHOICE. The controller may change its choice in writing until the services end.

Art. 28(3)(g) GDPR; EDPB Guidelines 07/2020, para. 140

At the end the controller decides: data back or data deleted, copies included. In the field, write either delete, or return and the format of the return.

11.2 The processor completes the deletion or return within NUMBER days, deletes securely, and confirms in writing that it has done so. If a law requires the processor to keep some of the data, it tells the controller which law and which data as soon as possible, and keeps protecting that data under this agreement until it is deleted.

EDPB Guidelines 07/2020, paras. 141-142

Deletion is confirmed in writing. Data kept because a law requires it stays protected.

12. Information and audits

12.1 The processor makes available to the controller all information necessary to demonstrate compliance with the obligations laid down in Article 28 GDPR, including information on the systems used, the security measures, data location, transfers, who has access to the data and the sub-processors used.

Art. 28(3)(h) GDPR; EDPB Guidelines 07/2020, para. 143

The controller can ask for everything it needs to show that the processing is in order.

12.2 The processor allows for and contributes to audits, including inspections, conducted by the controller or another auditor mandated by the controller, with NUMBER days' notice, or shorter notice where there are signs of non-compliance. The processor may propose an auditor; the controller decides. The controller may take into account certifications and audit reports held by the processor.

Art. 28(3)(h) GDPR; EDPB Guidelines 07/2020, para. 144; Decision 2021/915, Annex, Clause 7.6

The controller, or an auditor it chooses, can check the processor, on site if needed.

12.3 The costs of audits are borne as follows: COST RULE. No charge may be so high that it discourages the controller from using its rights under this clause.

EDPB Guidelines 07/2020, para. 145

The GDPR does not say who pays for audits. The EDPB warns against fees so high that audits stay on paper.

13. International transfers

13.1 The processor transfers personal data to a third country or an international organisation only on documented instructions from the controller, or where Union or Member State law to which it is subject requires it, and in either case only in compliance with Chapter V GDPR. The same applies to transfers by its sub-processors.

Art. 28(3)(a) and Art. 44 GDPR; EDPB Guidelines 07/2020, paras. 119-120

Data goes to a third country only if the controller says so and a valid transfer tool is in place.

13.2 The controller authorises the following transfers: AUTHORISED TRANSFERS, OR: NONE.

Art. 44 to 47 GDPR

For each transfer, write the country, the recipient, the purpose and the tool that makes it lawful: an adequacy decision (Article 45), standard data protection clauses (Article 46(2)(c)), binding corporate rules (Article 47) or another tool under Chapter V. If there is none, write: none.

The Commission's processor clauses *"do not by themselves ensure compliance with obligations related to international transfers in accordance with Chapter V"* GDPR (Decision 2021/915, Annex, Clause 1(f)). Where the processor is outside the territorial scope of the GDPR, the Commission's transfer clauses (Decision (EU) 2021/914) *"also fulfil the requirements of Article 28(3) and (4)"* (Decision 2021/915, recital 10).

14. Liability and costs

14.1 Each party is liable to data subjects as set out in Article 82 GDPR. Nothing in this agreement limits the rights of data subjects under that Article.

Art. 82 GDPR

Towards the people concerned, Article 82 decides: a processor is liable only for breaching duties aimed at processors, or for acting outside or against the controller's lawful instructions.

14.2 Liability between the parties, including any limit, is governed by LIABILITY TERMS.

Art. 82(5) GDPR

Article 82(5) lets a party that paid full compensation claim back the other's share. Any other split is for the parties to agree. In the field, either refer to the liability terms of the Main Contract or write the terms.

14.3 The processor's assistance under clauses 8, 9, 10 and 12 is PRICE OF THE ASSISTANCE.

Art. 28(3)(e), (f) and (h) GDPR

Article 28 requires the help but says nothing about its price. The parties agree it here: either included in the price of the Main Contract, or the charges written out.

15. Term and termination

15.1 This agreement takes effect on START DATE. It stays in force as long as the processor processes personal data on behalf of the controller, even after the Main Contract has ended, unless it is terminated earlier under clause 15.2 or 15.3. Clause 15.4 sets what applies after it ends.

Art. 28(3), first subparagraph (duration), GDPR

The agreement lasts as long as the processor holds the data, not only as long as the service. If it ends early, clause 15.4 keeps it applying until the data is gone.

15.2 The processor informs the controller without delay if it can no longer comply with this agreement, for whatever reason. If the processor breaches this agreement or the GDPR, the controller may instruct it to suspend the processing until it complies. If compliance is not restored within NUMBER days, or the breach is serious or persistent, the controller may terminate this agreement and the parts of the Main Contract that involve the processing.

Decision 2021/915, Annex, Clause 10(a)-(b)

The controller can stop the processing, and end the contract if the processor does not put things right. The Commission's clauses allow at most one month.

15.3 If the controller insists on an instruction that the processor has reported under clause 4.3 as infringing data protection law, the processor may terminate this agreement and the parts of the Main Contract that involve the processing.

EDPB Guidelines 07/2020, para. 149; Decision 2021/915, Annex, Clause 10(c)

The processor is not trapped by an unlawful instruction: it can end the contract.

15.4 After this agreement ends, for whatever reason, the processor continues to comply with all of it until all personal data have been deleted or returned. Clauses 5, 12 and 14 continue to apply after that for obligations and claims that arose before.

Decision 2021/915, Annex, Clause 10(d); Art. 28(3)(g) GDPR

The whole agreement keeps applying until the data is gone. Secrecy, audits and liability carry on after that for what happened before.

16. Form, changes and governing law

16.1 This agreement and any change to it are made in writing, which includes electronic form.

Art. 28(9) GDPR

A spoken or implied agreement does not count; an electronic one does.

16.2 The processor notifies any proposed change to this agreement directly to the controller. A change takes effect only when the controller approves it in writing. Publishing a change on the processor's website is not notice.

EDPB Guidelines 07/2020, para. 110

Changes are agreed with the controller, not posted online.

16.3 This agreement is governed by the law of MEMBER STATE. The courts of PLACE have jurisdiction. This does not affect the right of data subjects to bring proceedings under Article 79 and Article 82(6) GDPR.

Art. 79 and Art. 82(6) GDPR

The GDPR does not set the law or the courts of the agreement: the parties choose them under ordinary contract law. Data subjects keep their own right to go to court under Articles 79 and 82(6).

FOR THE CONTROLLER: NAME, ROLE, PLACE, DATE AND SIGNATURE _____ FOR THE PROCESSOR: NAME, ROLE, PLACE, DATE AND SIGNATURE _____

Annexes

Annex 1: Description of the processing

Describe each item concretely, then delete the examples in the fields.

ITEM	DESCRIPTION
Subject matter	WHAT THE PROCESSOR DOES, FOR EXAMPLE PAYROLL FOR THE CONTROLLER'S STAFF
Duration	EXACT PERIOD, OR THE CRITERIA THAT FIX IT
Nature of the processing	THE OPERATIONS, FOR EXAMPLE COLLECTION, STORAGE, CONSULTATION, TRANSMISSION, DELETION
Purpose or purposes	WHY THE DATA IS PROCESSED
Types of personal data	FOR EXAMPLE NAME, ADDRESS, BANK DETAILS, WORKING HOURS
Special categories (Article 9) or criminal data (Article 10), and the extra safeguards	WHICH TYPES AND WHICH SAFEGUARDS, OR WRITE: NONE
Categories of data subjects	FOR EXAMPLE EMPLOYEES, CUSTOMERS, VISITORS
Places of processing	COUNTRIES AND SITES, INCLUDING THOSE OF SUB-PROCESSORS

Annex 2: Technical and organisational measures

Describe each measure the processor actually applies, concretely, and the evidence for it. The list names areas to cover; it does not say which measures are enough. That depends on the risk (Article 32).

The Commission's model annex says: *"The technical and organisational measures need to be described concretely and not in a generic manner."* (Decision 2021/915, Annex III). The areas below follow Article 32(1) and the examples in that annex.

Part A. Security of processing

AREA	MEASURES APPLIED	EVIDENCE
Pseudonymisation and encryption of personal data (Art. 32(1)(a))	MEASURES	EVIDENCE
Ongoing confidentiality, integrity, availability and resilience of systems and services (Art. 32(1)(b))	MEASURES	EVIDENCE
Restoring availability of and access to data in time after an incident (Art. 32(1)(c))	MEASURES	EVIDENCE
Regular testing, assessing and evaluating of the measures (Art. 32(1)(d))	MEASURES	EVIDENCE
Identifying and authorising users	MEASURES	EVIDENCE
Protecting data in transit	MEASURES	EVIDENCE
Protecting stored data	MEASURES	EVIDENCE
Physical security of the places where data is processed	MEASURES	EVIDENCE
Logging of events	MEASURES	EVIDENCE
System configuration, including default settings	MEASURES	EVIDENCE

AREA	MEASURES APPLIED	EVIDENCE
Internal IT and IT security governance and management	MEASURES	EVIDENCE
Certification or assurance of processes and products	MEASURES	EVIDENCE
Data minimisation	MEASURES	EVIDENCE
Data quality	MEASURES	EVIDENCE
Limited retention	MEASURES	EVIDENCE
Accountability	MEASURES	EVIDENCE
Data portability and erasure	MEASURES	EVIDENCE

Part B. Assistance to the controller

DUTY OF THE CONTROLLER	HOW THE PROCESSOR HELPS
Answering requests from data subjects (Art. 28(3)(e))	FOR EXAMPLE FORWARDING WITHIN THE AGREED DAYS, EXPORT TOOLS, DELETION ON INSTRUCTION
Security of processing (Art. 32)	DESCRIBE
Breach notification and communication (Arts. 33 and 34)	DESCRIBE, INCLUDING THE BREACH CONTACT AND THE CONTENT OF THE NOTICE
Impact assessments and prior consultation (Arts. 35 and 36)	DESCRIBE

Annex 3: Sub-processors

List every sub-processor at every level of the chain. Under Option A this is the list of authorised sub-processors; under Option B it is the agreed list.

NAME AND ADDRESS	CONTACT PERSON	PROCESSING ACTIVITY	COUNTRY	TRANSFER TOOL, IF OUTSIDE THE EEA	DATE AUTHORISED
NAME AND ADDRESS	CONTACT	ACTIVITY	COUNTRY	TOOL OR: NONE	DATE
NAME AND ADDRESS	CONTACT	ACTIVITY	COUNTRY	TOOL OR: NONE	DATE

With each request or announced change, the processor sends the sub-processor's identity, its location, what it will do and the safeguards it has in place (EDPB Guidelines 07/2020, para. 152).

Annex 4: Contact points

Name a person and a channel for each role, and keep the list current.

ROLE	CONTROLLER	PROCESSOR
Giving and receiving instructions	NAME, ROLE, EMAIL	NAME, ROLE, EMAIL
Personal data breach notices	NAME, EMAIL, PHONE	NAME, EMAIL, PHONE
Requests from data subjects	NAME, EMAIL	NAME, EMAIL
Audits and information requests	NAME, EMAIL	NAME, EMAIL
Data protection officer, if designated	NAME AND CONTACT	NAME AND CONTACT

Does your existing agreement cover Article 28(3)?

Read the agreement already signed and tick Yes, No or ? for each line. ? means unknown: write who you asked. Each No is a gap against the article.

LINE	WHAT IT SAYS	YES	NO	?
Art. 28(3), first subparagraph GDPR	It sets out the subject matter and duration of the processing, its nature and purpose, the types of personal data, the categories of data subjects, and the controller's obligations and rights.	☐	☐	☐
Art. 28(3)(a) GDPR	The processor acts only on the controller's documented instructions, including on transfers to third countries or international organisations. If a Union or Member State law requires otherwise, the processor tells the controller first, unless that law forbids this on important grounds of public interest.	☐	☐	☐
Art. 28(3)(b) GDPR	The processor ensures that the persons authorised to process the data have committed to confidentiality or are under an appropriate statutory duty of confidentiality.	☐	☐	☐
Art. 28(3)(c) GDPR	The processor takes all the security measures required by Article 32.	☐	☐	☐
Art. 28(3)(d) GDPR	The processor respects the conditions of Article 28(2) and (4) for engaging another processor.	☐	☐	☐
Art. 28(3)(e) GDPR	Taking into account the nature of the processing, the processor helps the controller, by appropriate technical and organisational measures and insofar as possible, to respond to requests from data subjects exercising their rights.	☐	☐	☐
Art. 28(3)(f) GDPR	The processor helps the controller meet its duties under Articles 32 to 36 (security, breach notification and communication, impact assessments, prior consultation), taking into account the nature of the processing and the information available to it.	☐	☐	☐
Art. 28(3)(g) GDPR	When the services end, the processor deletes or returns all the personal data, as the controller chooses, and deletes existing copies, unless Union or Member State law requires storage.	☐	☐	☐
Art. 28(3)(h) GDPR	The processor makes available all information needed to demonstrate compliance with Article 28, and allows for and contributes to audits, including inspections, by the controller or an auditor the controller mandates.	☐	☐	☐
Art. 28(3), second subparagraph GDPR	The processor immediately informs the controller if, in its opinion, an instruction infringes the GDPR or other Union or Member State data protection provisions.	☐	☐	☐
Art. 28(2) GDPR	The processor engages another processor only with the controller's prior specific or general written authorisation. Under a general authorisation, it informs the controller of each intended addition or replacement, giving the controller the chance to object.	☐	☐	☐

LINE	WHAT IT SAYS	YES	NO	?
Art. 28(4) GDPR	Each sub-processor is bound, by contract or other legal act, to the same data protection obligations, and the processor remains fully liable to the controller for the sub-processor's performance.	☐	☐	☐
Art. 28(9) GDPR	The agreement is in writing, which may be electronic form.	☐	☐	☐

ITALY

Italy: what Italy's data protection authority (the Garante) and Personal Data Protection Code (Codice privacy, Legislative Decree 196/2003) add

Words. In Italian the processor is the *responsabile del trattamento*, a sub-processor a *sub-responsabile* and the controller the *titolare*. The *responsabile della protezione dei dati* (RPD) is the data protection officer, a different role (Garante, principi fondamentali del trattamento).

The contract designates the processor. The Garante describes the Article 28 contract as the act by which the controller *"designa un responsabile del trattamento attribuendogli specifici compiti"*, and says it must be *"un contratto (o altro atto giuridico conforme al diritto nazionale)"* covering at least the matters in Article 28(3) (Garante, principi fondamentali del trattamento). Its FAQ on records calls it the *"contratto di designazione a responsabile"* (Garante, FAQ sul registro).

Sub-processors. The same Garante page says the first processor answers to the controller for a sub-processor's failure, *"anche ai fini del risarcimento di eventuali danni"*, unless it proves that the event *"non gli è in alcun modo imputabile"* (Article 82(1) and (3) GDPR). Clause 7.4 of the model reflects Article 28(4).

Persons authorised to process. Under Article 2-quaterdecies of the Codice privacy, the controller or the processor *"individuano le modalità più opportune per autorizzare al trattamento dei dati personali le persone che operano sotto la propria autorità diretta"* (paragraph 2), and may assign specific tasks to expressly designated natural persons acting under their authority (paragraph 1) (Normattiva; Fino's copy). The article leaves the form of the authorisation open. It works alongside Article 29 GDPR and clause 5 of the model.

IT-5.3 The processor authorises, in documented form, the natural persons who process the personal data under its direct authority, and gives them instructions consistent with this agreement.

Art. 2-quaterdecies(2) Codice privacy; Art. 29 GDPR

Optional, for Italy: records who at the processor may handle the data. Fino's own wording; the Codice does not require this clause and does not prescribe the form.

The processor's own record. For the description of the categories of processing in its record under Article 30(2), the Garante says *"è possibile far riferimento a quanto contenuto nel contratto di designazione a responsabile"* (Garante, FAQ sul registro, point 6). A precise Annex 1 therefore serves both documents.

Breaches. The Garante's breach page says a processor that becomes aware of a breach *"è tenuto a informare tempestivamente il titolare"* (Garante, data breach). Clause 10.1 turns this into a number of hours.

Fined, and Article 28 among the breaches

Serfin 97 S.r.l., a debt collector acting as processor: €60,000, Garante, 2024. It added contact data on its own, without recording the source or passing it to the controller; the Garante found breaches of Article 28(3)(a), (e) and (h) (decision 2024/IT/132). **ISWEB S.p.A.**, a whistleblowing platform provider acting as processor: €40,000, Garante, 2022. It used a hosting provider without a proper Article 28 arrangement, including without a client hospital's prior authorisation (decision 2022/IT/103).

GERMANY

Germany: what the Federal Commissioner for Data Protection and Freedom of Information (BfDI), the conference of German data protection authorities (DSK) and the Criminal Code add

Words. In German the processor is the *Auftragsverarbeiter* and the controller the *Verantwortlicher*. The agreement appears as *Vereinbarung zur Auftragsverarbeitung* (BfDI) or *Auftragsverarbeitungsvertrag* (several state authorities).

The BfDI model. The Federal Commissioner publishes a *Mustervereinbarung zur Auftragsverarbeitung*, version 2.1, written for federal public bodies: in it the controller is the Federal Republic of Germany, represented by a public body (BfDI model). Beyond the bare article it provides: a right for the processor to suspend an instruction it considers unlawful until the controller confirms or changes it (section 3(5); compare clause 4.3); an annex naming who may give and who may receive instructions (compare Annex 4); notice of *"mindestens vier Wochen"* before a new sub-processor, under both the specific and the general option (section 8(1); compare clauses 7.1 and 7.2); the controller's prior consent for processing outside the processor's premises, such as home working (section 3(11)); and a plain reference to Article 82 GDPR for liability (section 10).

DE-3.11 The processor processes the personal data outside its own premises, including by staff working from home, only with the controller's prior consent in writing or in documented electronic form.

Federal Commissioner for Data Protection and Freedom of Information (BfDI) Mustervereinbarung zur Auftragsverarbeitung, version 2.1, section 3(11)

Optional: the BfDI model makes remote work on the data subject to the controller's consent. It is a model term, not a GDPR requirement.

Credit for the BfDI points: Source "Der Bundesbeauftragte für den Datenschutz und die Informationsfreiheit", Mustervereinbarung zur Auftragsverarbeitung, version 2.1, used under Datenlizenz Deutschland – Namensnennung – Version 2.0 (https://www.govdata.de/dl-de/by-2-0).

The DSK short paper. The conference of German data protection authorities (DSK) explains Article 28 in *Kurzpapier Nr. 13* (as of 17 December 2018). The DSK lists it as under revision (*"in Überarbeitung"*), and the paper itself says its view is subject to a possibly different EDPB interpretation (conference of German data protection authorities (DSK) Kurzpapier Nr. 13; DSK list). It says that IT maintenance and remote support where access to personal data cannot be excluded is processing on behalf, so Article 28 applies, while purely technical work on infrastructure such as power, cooling or heating is not. It also says that using a professional such as a tax adviser, lawyer, external company doctor or auditor is *"in der Regel"* not processing on behalf but the use of an independent controller (Annex B).

The EDPB's later guidelines give a conditional answer for an accounting firm: a controller in the EDPB's example, but a processor where the law sets no specific obligations for the firm and the client gives very detailed instructions (EDPB Guidelines 07/2020, example "Accountants", pp. 15-16). The role depends on the facts of each engagement.

Credit for the DSK points: Konferenz der unabhängigen Datenschutzbehörden des Bundes und der Länder (Datenschutzkonferenz). Datenlizenz Deutschland – Namensnennung – Version 2.0 (https://www.govdata.de/dl-de/by-2-0).

Professional secrecy (section 203 of the German Criminal Code (Strafgesetzbuch, StGB)). For doctors, lawyers and the other holders of professional secrets listed in section 203(1) and (2) StGB, Article 28 is not the only rule. They may disclose secrets to other persons who contribute to their work *"soweit dies für die Inanspruchnahme der Tätigkeit der sonstigen mitwirkenden Personen erforderlich ist"* (section 203(3)). They commit an offence if such a person discloses a secret without authorisation and they had not ensured that the person *"zur Geheimhaltung verpflichtet wurde"* (section 203(4), second sentence, no. 1) (gesetze-im-internet.de). The DSK paper makes the same link (Kurzpapier Nr. 13, p. 2).

DE-5.3 Where the controller is bound by professional secrecy under section 203(1) or (2) StGB: the processor is obliged to keep secret all third-party secrets it learns while performing this agreement, takes note of them only as far as necessary for its work, and obliges any further person it uses for this work to the same secrecy before that person starts.

Section 203(3) and (4) StGB

Optional, Fino's own wording, for doctors, lawyers, tax advisers and other holders of professional secrets in Germany. Under section 203(4) StGB, the secret holder commits an offence if a person helping with its work discloses a secret without authorisation and the holder had not made sure that person was obliged to secrecy. This clause is one way to record that obligation.

Professional rules can require more. For lawyers, for example, section 43e(3) of the Federal Lawyers' Act (Bundesrechtsanwaltsordnung, BRAO) says the contract with a service provider "bedarf der Textform" (must be in text form) and that the provider is to be obliged to secrecy "unter Belehrung über die strafrechtlichen Folgen einer Pflichtverletzung" (with instruction on the criminal consequences of a breach of duty) (section 43e BRAO).

Fined, and Article 28 among the breaches

Volkswagen: €1,100,000, Data Protection Authority of Niedersachsen, 2022. Among four breaches, there was no processor agreement with the service provider running research drives that recorded traffic (decision 2022/DE/050). **Vodafone GmbH**: €45,000,000 in two fines, final, the Federal Commissioner for Data Protection and Freedom of Information (BfDI), 2025. €15 million of it was imposed because Vodafone did not check and supervise its partner agencies sufficiently (Article 28(1)) (decision 2025/DE/006).

Decision data come from enforcementtracker.com (provided by CMS) and GDPRhub (noyb), under CC BY-NC-SA 4.0 (https://creativecommons.org/licenses/by-nc-sa/4.0/), and from regulators' own publications; each decision page on Fino carries the details.

Sources

GDPR, Regulation (EU) 2016/679 (EUR-Lex) • Used for: Articles 4, 24, 28, 29, 32, 33, 44 to 47, 79, 82; Fino's copies at finoprivacy.com/gdpr/

Commission Implementing Decision (EU) 2021/915, standard contractual clauses between controllers and processors (EUR-Lex) • Used for: The Commission route under Article 28(7); invariability; transfers not covered; breach notice wording; Annex III areas; termination structure

EDPB Guidelines 07/2020 on the concepts of controller and processor in the GDPR, version 2.1 • Used for: Who is a processor; content and detail of the contract; instructions, security, sub-processors, breach timeframe, deletion, audits and costs, unlawful instructions

EDPB Opinion 22/2024 on obligations following from the reliance on processors and sub-processors • Used for: Identity of all sub-processors; the 'required by law' wording

Joint Opinion 1/2021 of the EDPB and the European Data Protection Supervisor (EDPS) on standard contractual clauses between controllers and processors • Used for: Breach notification time left to the parties (para. 42)

EDPB register: standard contractual clauses and administrative arrangements • Used for: Article 28(8) clauses adopted by supervisory authorities (read 7 Nov 2026)

Garante: principi fondamentali del trattamento • Used for: Italy: terms, the designation contract, sub-processor liability

Garante: FAQ sul registro delle attività di trattamento • Used for: Italy: processor's record and the designation contract

Garante: data breach • Used for: Italy: processor informs the controller of a breach

Codice privacy (D.Lgs. 196/2003), art. 2-quaterdecies (Normattiva) • Used for: Italy: persons authorised to process

BfDI: Mustervereinbarung zur Auftragsverarbeitung, version 2.1 (Datenlizenz Deutschland Namensnennung 2.0) • Used for: Germany: structure and model terms (suspension, instructions annex, four weeks' notice, remote work, liability)

DSK: Kurzpapier Nr. 13, Auftragsverarbeitung, Art. 28 DS-GVO (as of 17 Dec 2018, under revision) • Used for: Germany: maintenance and remote access, professional secret holders, section 203 of the German Criminal Code (StGB)

Strafgesetzbuch, section 203 (gesetze-im-internet.de) • Used for: Germany: professional secrecy when using a processor

Datatilsynet (Denmark): standard contractual clauses for Article 28(3), English template • Used for: Structure only (order of clauses and annexes); no wording used

Datenschutzbehörde (Austria): Standardvertragsklauseln für die Zwecke nach Art. 28 DSGVO (January 2020) • Used for: Structure only; no wording used

Federal Lawyers' Act (Bundesrechtsanwaltsordnung, BRAO), section 43e (gesetze-im-internet.de) • Used for: Germany: example of professional rules on service providers (text form, secrecy obligation with instruction)